Both approaches generate OIDC tokens containing a small but useful set of claims:

- `sub`, `iss`, `aud`, and `tenant_id` for identity and scoping
- basic attributes such as email, name, and groups, that allow policies to resolve the subject without requiring directory synchronization
- optional claims like role or department for organizations that want finer control

These values map to Cedar entities like `ACME::Employee::"{guid}"` or `C3::CustomerUser::"{tenant_id}:{external_id}"`.

More dynamic or high-cardinality data—data with many possible distinct values like entitlement tiers or support status—comes from Policy Information Points (PIPs) during evaluation, keeping tokens small and reducing replication overhead.

13.3.3 Device posture for ACME employees

C³ only uses device-posture tokens for ACME employees. Since ACME manages its own fleet of devices, each company device can provide a signed posture token to prove compliance. The PEP verifies the posture token, decodes it and the employee's OIDC token, and then determines context for policy evaluation. Rather than forward raw tokens, the PEP sends the PDP a normalized PARC request:

- `principal`: mapped Cedar entity (for example, `ACME::Employee::"{guid}"`)
- `tenant_id`: from the employee's token (ACME's tenant)
- `action`: the application verb
- `resource`: the target of the action
- `context`: device posture, posture source, time, JWT ID, IP address, and so on

This allows the C³ PDP to enforce ACME's zero-trust baseline, which requires a compliant device for admin or cross-tenant operations, without